Análise de arquivo benigno ou malware

Share

exec.out

OUT

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Verificando as regras sobre código malicioso

Vou começar lendo o guia de leitura de arquivos e depois fazer uma análise estática do arquivo, sem executá-lo.

Read a file, ran a command

É um executável ELF de 64 bits (Linux x86-64), não stripped (ainda tem símbolos), com ~41 KB. O `xxd` não está disponível, então vou usar alternativas e examinar a estrutura do binário.

Ran 5 commands

As evidências já são fortes, mas a saída foi cortada em 200 linhas. Vou ver o restante das strings para não deixar nada de fora (por exemplo, indicadores de persistência ou ocultação).

Ran 2 commands

Fiz uma análise **estática**, sem executar o arquivo em nenhum momento. Passo a passo:

1. Tipo real do arquivo. Apesar da extensão `.out`, é um executável **ELF de 64 bits para Linux x86-64** (PIE, dinâmico) de 41.072 bytes, compilado com GCC 14.2.0 (Debian) e **não stripped**, ou seja, ainda guarda os nomes de funções e variáveis.
SHA-256: `3d5b7f663a3654a699c0512d54762a9a8d4b1adcdaaddacdc8784f87df9c66a3`

2. Estrutura. Nada anômalo: seções padrão, sem packer ou ofuscação, sem segmentos com permissão RWX, dependência apenas da `libc`. Isso é neutro, pois um malware simples e sem ofuscação tem exatamente essa aparência.

3. Funções importadas. Há uma combinação pouco comum: sockets (`socket`, `connect`, `bind`, `listen`, `accept`, `recv`, `sendto`), execução de comandos (`popen`), controle de processos (`fork`, `kill`, `waitpid`) e manipulação de IPs (`inet_network`). Isso só indica suspeita, não prova nada.

4. Símbolos internos. Aqui o quadro fica claro: `_NICK`, `_PING`, `_PRIVMSG`, `_376`, `_433` (protocolo IRC), além de `identd`, `udp`, `pan`, `tsunami`, `spoof`, `in_cksum` (checksum para montar pacotes brutos), `flooders`, `killall` e `execfile`.

5. Strings embutidas. Confirmam a função do programa:

- Quatro servidores IRC fixos no código (`irc.qeast.net`, `irc2.magic.ca`, `irc.east.gblx.net`, `irc.west.gblx.net`) e o canal `#whatever`, que funcionam como infraestrutura de comando e controle.
- Um conjunto de comandos que um operador remoto envia ao bot: floods (`UDP`, `PAN`, `TSUNAMI`, `UNKNOWN`), falsificação de IP de origem (`SPOOFS`), execução de shell (`SH`), download de arquivos via HTTP (`GET`), `KILL`, `SERVER` e outros.
- A frase `Kaiten wa goraku`, que identifica o bot **Kaiten**.

6. Comportamento no código. Examinei o início de `main()` para entender a string `-bash`. O programa executa `fork()`, o processo pai encerra e o filho continua em segundo plano. Depois, ele sobrescreve o próprio nome de processo (`argv[0]`) com `-bash`, para parecer um shell de login em listagens como o `ps`. Rodar escondido e se disfarçar é típico de malware.

7. O que não encontrei. Não há persistência embutida (cron, rc.local, systemd), exploração de vulnerabilidades nem criptografia. É um bot clássico e simples, mas nem por isso é inofensivo.

Veredito: é malware. Trata-se de um **bot IRC de DDoS com função de backdoor, da família Kaiten (também chamada Tsunami por antivírus)**, compilado a partir de código-fonte público (o arquivo original se chamava `codigo.c`). Ele recebe ordens remotas, executa comandos arbitrários no sistema, lança floods com IP falsificado, baixa arquivos e se camufla como `-bash`. Nenhuma finalidade legítima explica essa combinação. Minha confiança é alta.

Algumas ressalvas importantes:

- O binário parece ter sido compilado recentemente a partir de código antigo, então o hash provavelmente não consta em bases como o VirusTotal. "Não encontrado" ali não significaria que é seguro.
- Como não executei o arquivo, não testei se os servidores IRC ainda respondem. A classificação se baseia no que o código é capaz de fazer.
- Se você o compilou para estudo, mantenha-o apenas em uma VM isolada e sem rede. Se o encontrou ou recebeu de terceiros, não o execute. Isole a máquina, procure processos chamados `-bash` sem terminal associado e conexões de saída para servidores IRC (tipicamente porta 6667), e trate o caso como comprometimento (troca de credenciais, reinstalação).

Posso ajudar com detecção e resposta, como regras de bloqueio baseadas nesses indicadores ou como investigar um servidor suspeito. Não posso ajudar a modificar, recompilar ou operar esse tipo de código.

Qual é a categoria principal deste malware?

Escolhendo o rótulo principal e os papéis secundários ▸

A categoria principal é **bot de DDoS (agente de botnet) controlado via IRC**.

O propósito central do código é transformar a máquina infectada em um "zumbi" que recebe ordens de um servidor IRC (o C2) e ataca alvos com floods de rede, usando IP de origem falsificado. A maior parte do código e do menu de comandos gira em torno disso: as funções de flood, o spoofing de IP e o cálculo de checksum para pacotes brutos.

Ele também tem características secundárias de **backdoor** (executa comandos de shell remotamente) e **downloader** (baixa arquivos via HTTP). Essas funções dão suporte ao papel de bot, e por isso alguns antivírus o rotulam de forma genérica como "Backdoor" ou "Trojan". Se você precisar de um único rótulo para um relatório, o mais preciso é **Botnet / DDoS bot (família Kaiten/Tsunami), com C2 via IRC**.